



DOCUMENT D'EXPLOITATION · CONFIDENTIEL

Plan de Reprise d'Activité (PRA)

Sauvegarde, continuité et reprise du Hub Astorya (ERP/CRM) : application, base de données, code, secrets et services — objectifs RTO/RPO, scénarios de sinistre et procédures.

ÉDITEUR	S.A.R.L. ASTORYA S.G.I. · SIRET 523 625 804 00027	PÉRIMÈTRE	Hub Astorya — app, BDD, services
VERSION	1.0 — 03/09/2026	RESPONSABLE	Gérant (R. Daviaud)
DIFFUSION	Interne / confidentiel	RÉVISION	Annuelle ou post-incident

1 Objet & périmètre

Ce plan décrit les mesures de **sauvegarde**, de **continuité** et de **reprise** du Hub Astorya en cas d'incident majeur (indisponibilité, corruption, compromission, sinistre). Il couvre l'application (front statique + fonctions serverless, Vercel), la base de données (Supabase/PostgreSQL), le code source (GitHub) et la chaîne de déploiement, les secrets & configurations, les services tiers (Pappers, Dropcontact, Brave, SendGrid, Google Calendar, 3CX, IA) et la téléphonie 3CX.

Hors périmètre : postes de travail individuels, réseau local du client, opérateurs télécom.

2 Définitions

Terme	Définition
RTO	Durée maximale d'interruption admissible avant reprise.
RPO	Perte de données maximale admissible (fenêtre de sauvegarde).
Sinistre	Événement rendant un service indisponible au-delà du seuil toléré.
Bascule	Reprise du service sur une infrastructure/copie de secours.
Règle 3-2-1	3 copies des données, sur 2 supports, dont 1 hors-ligne/hors-site.

3 Rôles & cellule de crise

Rôle	Responsable	Missions
Responsable PRA	Gérant — R. Daviaud	Déclenche le plan, décide de la bascule, communique.
Référent technique	<i>à désigner</i>	Restaurations, redéploiements, rotation des secrets.
Suppléant	<i>à désigner</i>	Continuité si le référent est indisponible.
Communication	Gérant	Informe clients & équipe.

Contacts fournisseurs (à compléter) : Vercel, Supabase (projet `cqdgecllzyqimfuovrpp`), registrar DNS, OVH (serveur cible), opérateur 3CX, SendGrid.

4 Objectifs de reprise (RTO / RPO)

Composant	Criticité	RTO	RPO	Moyen de reprise
Application (front + /api)	Vitale	≤ 1 h	0	Redéploiement Git → Vercel (stateless)
Base de données (Supabase)	Vitale	≤ 4 h	≤ 5 min	PITR ; copie froide ≤ 24 h
Secrets & configuration	Vitale	≤ 1 h	0	Coffre-fort + variables d'env
DNS / domaine	Vitale	≤ 2 h	0	Modification zone (registrar)
Envoi d'e-mails (SendGrid)	Importante	≤ 2 h	0	Clé de secours ; dégradé Outlook
Téléphonie 3CX	Importante	≤ 4 h	n/a	Renvoi opérateur ; hotline dégradée
Enrichissement (Pappers, Dropcontact, Brave)	Secondaire	≤ 48 h	n/a	Mode dégradé, non bloquant

Objectifs globaux : $RTO \leq 4 \text{ h}$ · $RPO \leq 1 \text{ h}$ pour le socle vital.

5 Dispositif de sauvegarde

- **Base de données** : sauvegardes automatiques Supabase avec **restauration point-in-time (PITR)** ; **export logique** régulier (`pg_dump`) stocké **hors-ligne / hors-site** (règle 3-2-1, conforme ANSSI).
- **Code source** : **GitHub** = source de vérité (historique complet, branches protégées) ; front pré-compilé (`dist/`) versionné → reconstruction sans dépendance externe.
- **Secrets** : gestionnaire de mots de passe / coffre-fort + variables d'environnement Vercel ; liste des variables maintenue.
- **Documents comptables** : exports **FEC** et pièces archivés (conformité DGFIP).
- **Infrastructure** : `vercel.json`, scripts, mappings — versionnés dans Git.

6 Scénarios de sinistre & procédures

S1 — Indisponibilité de l'hébergeur edge (Vercel)

RTO ≤ 1 h

Impact : application inaccessible.

Reprise : vérifier l'état Vercel → si panne prolongée, redéployer le dépôt Git sur une instance de secours (nouveau projet Vercel ou serveur OVH) → repointer le DNS.

S2 — Indisponibilité / corruption de la base (Supabase)

RTO ≤ 4 h · RPO ≤ 5 min

Reprise : PITR vers l'instant précédant l'incident → si projet perdu, recréer un projet Supabase et restaurer l'export logique → mettre à jour SUPABASE_URL/clés.

S3 — Rançongiciel / compromission de données

RTO ≤ 8 h · RPO ≤ 24 h

Reprise : isoler (révoquer clés & sessions, couper les accès) → restaurer depuis la **copie hors-ligne** (non chiffrable par l'attaquant) → rotation complète des secrets → analyse post-incident.

La copie hors-ligne 3-2-1 est la garantie clé.

S4 — Perte / fuite de secrets

RTO ≤ 1 h

Reprise : rotation immédiate des clés (Supabase service_role, Pappers, Dropcontact, Brave, SendGrid, Google SA, secret 3CX) → mise à jour des variables d'env → redéploiement.

S5 — Panne DNS / domaine

RTO ≤ 2 h

Reprise : vérifier la zone chez le registrar → recréer les A/CNAME vers l'edge → propagation (TTL). Prévoir un **TTL court** avant toute opération planifiée.

S6 — Indisponibilité de GitHub

RTO ≤ 4 h

Impact : déploiements bloqués (service en ligne non impacté).

Reprise : utiliser un miroir / clone local à jour ; déployer manuellement si besoin.

S7 — Panne de téléphonie (3CX)

RTO ≤ 4 h

Reprise : renvoi d'appel opérateur ; hotline en mode dégradé (e-mail/ticket) ; le webhook /api/3cx-webhook reprend au rétablissement.

S8 — Sinistre majeur → bascule serveur OVH dédié (cible)

RTO ≤ 8 h · RPO ≤ 1 h

Reprise : déployer le dépôt sur le serveur OVH (France) → restaurer la base (PITR/export) → injecter les secrets → repointer le DNS → valider.

7 Procédure générale (synthèse)

1. **Qualifier** l'incident (composant, gravité) et **déclencher** le PRA.
2. **Isoler** si compromission (révocation clés/sessions).
3. **Restaurer** la donnée (PITR ou export hors-ligne) sur l'infra saine.
4. **Redéployer** l'application depuis Git.
5. **Réinjecter** les secrets (rotation si nécessaire).
6. **Repointer le DNS** vers l'infra de reprise.
7. **Vérifier** les flux critiques (connexion, facturation, contrats, e-mail).
8. **Communiquer** aux utilisateurs ; **documenter** (post-mortem).

8 Tests du plan

Test	Fréquence	Objet
Restauration BDD (sandbox)	Trimestrielle	Vérifier PITR + export ; mesurer le temps réel.
Redéploiement application	Semestrielle	Reconstruire depuis Git sur instance neuve.
Rotation de secrets	Semestrielle	Vérifier la procédure, sans interruption.
Exercice PRA complet	Annuelle	Scénario S8 (basculer OVH) de bout en bout.

Chaque test est **daté et consigné** (résultat, écarts, actions correctives).

9 Communication de crise & annexes

Interne : information immédiate de l'équipe. **Clients** : message factuel (nature, impact, délai) + point de rétablissement. **Fournisseurs** : ouverture de ticket support si nécessaire.

- **A.** Inventaire composants & régions → `infrastructure(-ops).html`.
- **B.** Liste des variables d'environnement → `infrastructure.md`.
- **C.** Fiche contacts (RPCA, référent, fournisseurs) — à *compléter*.
- **D.** Journal des tests PRA — à *tenir à jour*.

S.A.R.L. ASTORYA S.G.I. — 9 rue du Petit Châtelier, 44300 Nantes · SIRET 523 625 804 00027

PRA · Confidentiel · v1.0